

What do we mean by a compromised account and how would you know if this has happened?



One of the questions (A7.13) in the Cyber Essentials self-assessment asks **Do you have a process for when you believe the passwords or accounts have been compromised?**

Clearly, the correct answer is yes! But the bigger question is surely, **Would you and your staff know if your account had been compromised?**

What is a compromised account?

A compromised account refers to any account that is accessed by an **unauthorised** user with login details (username and password).

This can happen for a variety of reasons that include:

- using a weak password that can be guessed or brute forced
- failure to enable Multi-Factor Authentication (MFA) on online accounts
- a public data breach
- falling for a phishing scam
- having malware unknowingly installed on your device

How will I know?

You may be notified by the manufacturer or a supplier that there is a security weakness in their product or you may notice irregular things on your account such as your email account is sending messages that you did not create or your passwords have been changed and files, applications or services may have been deleted, changed or cannot be accessed.

Far from always being obvious, [according to IBM](#), it can take a company 197 days to discover a breach.

What should I do?

As soon as you suspect something is not right, you will need to immediately change your password to something unique and over 12 characters long and if possible, enable multi-factor authentication. Then, notify your contacts and if serious, [Action Fraud](#).

Account compromise also raises the important issue about who controls your accounts and passwords.

Many organisations put their faith in their IT service provider who manage their firewall router and the admin password to their accounts. It must be noted, however, that one of the possible places your passwords can be compromised is at your IT provider.

What would you do if your password is compromised or lost by your IT provider?

Consider what would happen if your IT provider became indisposed, or got a rogue employee who changed all your passwords. Would you know how to access your own accounts? your own firewall? Would you know how to change the password?

Business owners should not rely solely on their IT providers with sensitive information like passwords, as there is a risk of compromise through insider attacks, lost passwords or if the IT provider suffered a cyber breach. The IT provider is a third party consultant who assists a business, but they do not own the accounts or the business responsibility. The accounts and the passwords are the property and responsibility of the business owner.

Likewise, IT providers must respect their client's ownership of their accounts and not claim ownership or control over account administration, as it can lead to security risks and disputes.

Unfortunately, although your IT provider may be able to help you complete the Cyber Essentials questionnaire, you cannot pass on the full responsibility of this to them. The business owner is ultimately responsible and accountable for the answers and must digitally sign the submission to acknowledge that.

Cyber Essentials is generally considered the minimum level of certification for a UK organisation to prove that it is compliant with the basic controls that would prevent the majority of cyber-attacks. It is highly recommended that you look for an IT provider that is Cyber Essentials certified themselves. This demonstrates to you that the provider is serious about cyber security as well as being supportive when it comes to implementing the controls to your network. [Text for example article](#).